

Daily Vulnerability Report - 2026-09-12

Window (UTC): 2026-09-12T00:00 to 2026-09-13T00:00 | Sources: NVD, CISA KEV, FIRST EPSS | Generated 2026-09-17 05:58:18 UTC

Total	KEV (exploited)	Critical	High	Medium	Low	Unscored	Watchlist
117	8	14	45	50	4	4	31

P1 - Act now (KEV / high EPSS)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-85706	10.0	CRIT	Yes	0.12	gitlab:gitlab	GitLab has remediated an issue in GitLab CE/EE affecting all versions from 18.7 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that, under certain conditions, an unauthenticated user could have read arbitrary files from the GitLab server due to improper path confinement and missing authentication enforcement in the repository commits API.
CVE-2026-84869	9.9	CRIT	Yes	0.007	connectwise:screenconnect	A condition in the ScreenConnect client may allow files to be transferred and executed through an active remote session without authorization or Host confirmation in certain circumstances. ScreenConnect servers are not impacted.
CVE-2026-42016	8.8	HIGH	Yes	0.009	jfrog:artifactory	JFrog Artifactory (Self Hosted) versions before 7.133.11 are vulnerable to a privilege escalation attack due to a validation check of the token signature/issuer and not the token's scope.
CVE-2026-42018	7.5	HIGH	Yes	0.009	jfrog:artifactory	JFrog Artifactory could return an internal anonymous-user token to an unauthenticated caller when anonymous access is disabled, potentially exposing sensitive resources.
CVE-2026-58704			Yes	0.001	google:pixel	Google Pixel devices contain an improper authorization vulnerability in the cellular modem. A logic error may allow an attacker to bypass permission checks and escalate privileges.
CVE-2026-76460			Yes		cisco:identity services engine	Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) contain an incorrect use of privileged APIs vulnerability that could allow an unauthenticated, remote attacker to gain unauthorized access to the affected device by bypassing the web-based management interface.
CVE-2026-76461			Yes	0.02	cisco:secure email gateway	Cisco AsyncOS software for Cisco Secure Email Gateway (SEG) contains a SQL injection vulnerability that could allow an unauthenticated, remote attacker to execute arbitrary commands with root privileges on the underlying operating system.
CVE-2026-87886			Yes		acronis:backup	Acronis Backup plugin for cPanel & WHM and extension for Plesk contains an incorrect default permissions vulnerability that could allow for privilege escalation.

P2 - High (CVSS >= 9.0 or 7.0+ with EPSS >= 0.10)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-82845	9.9	CRIT		0.004		The Masteriyo LMS WordPress plugin before 3.4.1 does not prevent user-supplied values held as metadata from being deserialized when they are read back, allowing users with a minimal account to inject arbitrary PHP objects and, by way of a class shipped in a library bundled with the Masteriyo LMS WordPress plugin before 3.4.1, write and execute arbitrary code on the server. A weaker form of the same issue is reac...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-87719	9.9	CRIT		0.006		GitLab has remediated an issue in GitLab EE affecting all versions from 18.3 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that under certain conditions could allow an authenticated user with Duo Chat access to obtain Advanced Search instance configurations and sensitive credentials using a specially crafted GraphQL subscription argument to bypass serialization and perform server object lookup.
CVE-2026-75800	9.8	CRIT		0.004		The Frontegg SAML SSO WordPress plugin through 1.0.1 does not verify the signature or issuer of SAML authentication responses before establishing a session, allowing unauthenticated attackers to log in as any user, including administrators, as well as to create arbitrary accounts.
CVE-2026-78006	9.8	CRIT		0.008		The The Events Calendar plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 6.17.4 via the is_safe_widget_instance function. This is due to insufficient protection in is_safe_widget_instance, which can be bypassed because PHP fires magic methods during its pre-parse, combined with enable_rendering_widget_copied() forging a valid wp_hash integrity attribute before unser...
CVE-2026-78159	9.8	CRIT		0.008		The The Events Calendar plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 6.17.3 via the parse_array function. This is due to insufficient validation of the widget 'classes' map, allowing a plain-array payload to bypass the is_safe_widget_instance() object check and reach the callable-invocation sink in Element_Classes::parse_array(). This makes it possible for unaut...
CVE-2026-81402	9.8	CRIT		0.004		The DS Ad Rotator WordPress plugin through 0.8 does not perform any capability check, nonce verification, or file-type validation on its image upload handler, allowing unauthenticated attackers to upload arbitrary files, including PHP, to a web-accessible directory, which can lead to remote code execution.
CVE-2026-84171	9.8	CRIT		0.004		The WP images upload on piclect WordPress plugin through 1.0 does not validate the name or type of uploaded files before writing them to a publicly accessible directory, allowing unauthenticated attackers to upload arbitrary files and execute arbitrary code on the server.
CVE-2026-85681	9.8	CRIT		0.003		The WP Component WordPress plugin through 2.2.4 does not have any capability or nonce checks on one of the actions it makes available to unauthenticated users, and it takes both the option name and the option value from the request, allowing unauthenticated attackers to overwrite any of the site's options. On a single site installation this leads to a full takeover, as registration can be enabled with a default ro...
CVE-2026-77005	9.6	CRIT		0.003		The CODE MONKEYS PROPOSALS WordPress plugin through 1.0.1 does not validate a user-supplied file path before deleting a file, and does not check the capability of the user making the request, allowing any authenticated user, such as a subscriber, to delete arbitrary files on the server, which can lead to a site takeover.
CVE-2026-77006	9.6	CRIT		0.002		The WebTotem Backups WordPress plugin through 1.0.1 does not validate a user-supplied file path, does not check the capability of the user making the request, and discards the result of its own CSRF check, allowing any authenticated user, such as a subscriber, to delete arbitrary files on the server, which can lead to a site takeover.
CVE-2026-90558	9.3	CRIT		0.005		sngrep through 1.8.4 contains stack buffer overflow vulnerabilities in SIP attribute formatting routines when header values exceed the 255-byte buffer limit. Attackers can craft malicious SIP packets with oversized Call-ID, X-Call-ID, or other header fields to overflow stack buffers and cause crashes or execute arbitrary code during packet parsing and rendering.
CVE-2026-90647	9.1	CRIT		0.001		ASE/Kalkitech ASE2000 V2 Communication Test Set 2.35 through 2.37 on Windows contains an improper certificate validation vulnerability in the IEC 60870-5-104 TLS client (Task Mode). This allows a network-positioned attacker to bypass certificate validation via a certificate with multiple simultaneous faults, enabling a Man-in-the-Middle attack on protected communications.

Watchlist matches (other priorities)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-86169	8.7	HIGH		0.005		Axolotl before 0.19.0 contains a remote code execution vulnerability in the multipack patch path where trust_remote_code defaults to None instead of False, causing the security guard to be bypassed. Attackers can execute arbitrary Python code by crafting a malicious Hugging Face model repository selected as base_model, which is loaded with hardcoded trust_remote_code=True during AutoModelForCausalLM.from_pretrained.
CVE-2026-90559	8.7	HIGH		0.004		snappy-java through 1.1.10.8 contains an out-of-bounds write vulnerability in Snappy.uncompress(ByteBuffer, ByteBuffer) because destination buffer capacity is never validated against decompressed size. Attackers can supply valid compressed data that decompresses larger than the destination buffer, causing writes past buffer boundaries and JVM termination.
CVE-2026-87888	8.0	HIGH		0.002		The YayPricing WordPress plugin before 3.5.7 does not perform an authorization check on a REST route that saves its pricing rules, allowing users with the subscriber role and above to store JavaScript that executes in the browser of an administrator who opens the YayPricing WordPress plugin before 3.5.7's settings page.
CVE-2026-72996	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73002	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-73007	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-78448	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83954	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83967	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-83970	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83971	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83972	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83973	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83977	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83980	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83981	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83982	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-83983	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83985	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83987	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-90472	6.9	MEDI		0.003		msgpack-java through 0.9.12 contains a stack overflow vulnerability in MessageUnpacker.unpackValue() that recursively deserializes arrays and maps without nesting depth limits. Attackers can craft payloads with deeply nested arrays to exhaust the deserializing thread's stack and trigger StackOverflowError, causing per-request deserialization failures.
CVE-2026-90473	6.9	MEDI		0.002		msgpack-java through 0.9.12 contains an integer overflow vulnerability in MessageUnpacker.skipValue() when processing MAP32 containers with large element counts. Attackers can supply a MAP32 element count at or above 0x40000000 that wraps when doubled, causing the parser cursor to desynchronize and attacker-controlled data to be returned in place of later fields.
CVE-2026-90534	6.1	MEDI		0.002	flowiseai:flowise	Flowise is a low-code platform for building LLM applications. In versions up to and including 3.1.3, the POST /api/v1/node-load-method/:name endpoint is mounted without any route-level permission check and invokes component loadMethods with an attacker-controlled nodeName, loadMethod, inputs, and credential value. The selected credential is resolved by raw Credential.id via getCredentialData() and decrypted withou...
CVE-2026-89268	5.1	MEDI		0.002		QloApps through 1.7.0 renders back-office list filter POST parameters into HTML input value attributes without escaping them in the list helper template. Attackers can induce authenticated users to submit crafted POST requests with malicious payloads to list controllers, executing arbitrary JavaScript in the victim's session to read administrative data and perform actions.
CVE-2026-79300	3.5	LOW		0.002		SEP sesam before 5.2.0.24 mishandles User Authorization with MFA. If AD authentication is configured and MFA is enforced, an attacker can create a second OTP access capability. SEP sesam and Active Directory handle username capitalization differently, which may allow multiple SEP sesam user accounts to be created for the same Active Directory (AD) account. Active Directory treats usernames as case-insensitive, whi...
CVE-2026-90487	2.1	LOW		0.002		A vulnerability was found in Xuxueli xxl-job up to 3.4.2. Affected by this issue is some unknown functionality of the file xxl-job-admin/src/main/java/com/xxl/job/admin/business/controller/JobGroupController.java. The manipulation results in improper privilege management. The attack may be launched remotely. The exploit has been made public and could be used. The vendor was contacted early about this disclosure bu...

P3/P4 items (97) are in the Excel report. Unscored CVEs are newly published and awaiting NVD analysis; re-check tomorrow's report.